

Step 1: The need for a DPIA

DIPA Introduction	The Data Protection Impact Assessment (DPIA) is typically required for projects that involve the collection, processing, or storage of personal information. Bundoora Family Clinic's proposed prescription and medical tracking management system will handle highly sensitive patient data.
The aim of the project	The new system aims to enable doctors to issue digital prescriptions and access patients' past and present medical histories. Doctors and pharmacists will also have access to prescription details and medication inventory, which will be managed through a centralized digital system. This system will replace the clinic's current manual and paper-based processes.
Type of processing	The Data Protection Impact Assessment (DPIA) is typically required for projects that involve the collection, processing, or storage of personal information. Bundoora Family Clinic's proposed prescription and medical tracking management system will handle highly sensitive patient data.
The need for DIPA	The clinic processes patients' personal data for legitimate and relevant medical purposes. This includes sensitive information such as patients' medical histories, system activity logs, prescription details, and other related records. It also improves operational efficiency, and handles error reduction. Therefore, a DPIA is necessary to assess and manage the privacy risks associated with collecting, storing, and processing this information.

Step 1: The nature of processing

Data Collection	The clinic collects detailed information about relevant data-processing activities through various sources of personal information. These include patient registration, prescription management, medical histories, and reports recorded in patients' medical records. This personal medical data is collected for specific processing purposes and retained in accordance with the clinic's data-retention requirements.
Data Usage	The collected data is primarily used to provide patients with available healthcare services, including issuing and managing prescriptions, scheduling appointments, supporting doctor consultations, monitoring medication, providing counselling, and generating healthcare-related reports.
Data storage	The data is encrypted within the system and stored securely on the clinic's server.
Data deletion	The prescription and medical data is automatically or routinely deleted permanently by the patients. An authorized user (admin) can manage and initiate archival according to legal requirements. However, all deletions will be logged in the audit logs.

Data Source	The users are the sources of all the information, including doctors, patients, pharmacists, and administrators.
Data Sharing	Only authorized users can share sensitive data. No user can access data if their role is not specified, and access to sensitive data requires permission granted to certain roles only, such as patients themselves, administrators, and doctors. No external users are allowed.
High- Risk Processing	Personal medical information is strictly used for processing purposes only and is retained in accordance with the system requirements and applicable laws. If the organization identifies a risk, it can document the mitigation measures and implement additional technical safeguards, such as strong encryption and MFA for access control, in accordance with the principle of data protection by design.

Scope of Processing

Nature of data	Login credentials of all users (name, email, password, and date of birth), medical history, audit logs, and detailed prescription information, including medication details, inventory stock, the person in possession of the prescription, who issued the prescription, and any transfers or updates made to the prescription for affected parties.
Special Category of Data	Health information, including treatment, medication, allergies, and doctors' notes.

Amount of data	All past and present doctors, patients, and staff information, as well as clinic information, make up the amount of data.
Frequency	The frequency of data processing is dependent on user interaction.
Retention Period	A health service provider must not delete health information relating to an individual, even if it is later found or claimed to be inaccurate, unless the deletion is permitted, authorized or required by the regulations or any other law. The retention of medical records is based on Australian healthcare legislation and, specifically, the Victorian Health Records Act 2001 (Vic), as the Bundoora Family Clinic is located in Victoria.
Individuals Affected	Patients, doctors, pharmacists, administrators, and other clinic staff.
Geographical Area	West Melbourne, Victoria, Australia.

The context of the processing

Relationship with Individuals	The data is closely linked to identifiable individuals and contains personal and health information used to identify individuals and manage their healthcare, prescriptions, and medication records.
Individual Control	Patients may update their personal information, view their prescriptions, request prescription renewals, and exercise their privacy rights. Doctors may access and update relevant patient information, manage prescriptions, and add clinical notes. Administrators can manage, edit, and delete user and system information in accordance with their authorized access permissions.

User Expectations	All users expect the clinic to protect the information they provide and ensure that it is securely managed and handled using safe and appropriate procedures.
Vulnerable Groups	For vulnerable groups, such as elderly people and children, the system may be complex to use.
Existing Concerns	The clinic currently handles documents manually, which may cause: • Loss or misplacement of records. • Unauthorized access to sensitive data. • Human errors in record-keeping.
Novel Technology	AI Decision Support, Digital Prescription Technology, and Real-Time Medication Inventory Tracking.
Current Technology	Manual, paper-based system for managing all information.
Public Concerns	Since moving to a digital system, the public may be concerned about cybersecurity and data privacy risks, while elderly users may require assistance due to difficulties using digital technology. Some users may also have a general fear or lack of confidence in digital systems.
Standards Followed	Role-Based Access Control (RBAC), encrypted storage, secure password hashing (bcrypt), audit logging, WCAG accessibility standards and Australian Privacy standards.

Purposes of the processing

Purpose	To securely manage digital prescriptions, medication tracking, pharmacy inventory, and patient healthcare information. mix this with
---------	--

	a process designed to identify risks arising out of the processing of personal data and to minimize these risks as far and as early as possible.
Intended Effect	The system integrates a module that provides secure data storage, fast retrieval, easy updates and search functions, while well-designed reports reduce manual labour.
Benefits	The system enables fast processing of prescriptions, appointment bookings, medical tests, medication management, and doctor consultations.

Step 3: Consulting Process

Individuals and their views	Patients, Doctors, Pharmacists, Clinic Staff, Practice Manager, Developers, DPO, and Information Security Experts
Appropriate to consult	Patients, Doctors, Pharmacists, Reception Staff, Practice Manager, Developers, DPO (if and when applicable only) , and Information Security Experts (if the system requires only).
Patients	Provide views on privacy, accessibility and usability.
Doctors	Review prescription and patient-data processes.
Pharmacists	Review prescription and medication workflows.
Clinic Staff	Review registration and appointment processes.
Practice Manager	Ensure operational and compliance requirements are met.
System Developers	Implement privacy and security requirements.
DPO	Review privacy risks and DPIA compliance.

Security Experts	Assess cybersecurity risks and security controls.
------------------	---

Step 4: Assess necessity and proportionality

Lawful Basis	The patient's consent is obtained for the collection of their information, which is used only for primary healthcare purposes. Data is disclosed only when required or permitted under Australian law.
Necessity	Highly necessary and in accordance with applicable Australian privacy legislation and the Australian Privacy Principles.
Alternative Methods	• Hybrid system • AI-assisted system • Highly automated system
Prevention Of Function Creep	Function creep will be prevented by limiting data collection and processing to defined healthcare purposes, implementing role-based access controls, maintaining audit logs, obtaining consent where required, and reviewing any proposed secondary use of personal information before implementation.
Data Minimisation	By collecting only the important information from the users.
Data Quality	Input validation, maintaining audit logs, and controlled database access help maintain data quality and reduce errors.
Providing Information	Through transparency, the privacy notice explains what data is collected, why it is processed, and the users' rights.

Individual Rights	As permitted under applicable law, users can exercise control over their data, including requesting access, correction, or archiving of their information.
Processor Compliance	Third parties who sign up to the system or authorised external users, such as IT specialists, should undergo verification and comply with the required access and security procedures.
International Transfers	International data transfers have not yet been considered. If required, they will be conducted in accordance with applicable Australian privacy laws.

Step 5: Identify and assess risks

Source of risk and nature of potential impact on individuals (Including associated compliance and corporate risk)	Likelihood of harm (Remote, possible or probable)	Severity of harm (Minimal, significant or severe)	Overall risk (Low, medium or high)
Limited improvement in health outcomes	Possible	Possible	Medium
High implementation and training costs	Possible	Possible	Medium
Internet dependency and reduced interaction	Possible	Possible	Medium
Downtime increases prescribing errors	Possible	Possible	High
Inaccurate stock without monitoring	Possible	Possible	Medium
Non-compliance reduces system effectiveness	Possible	Possible	Medium

Unauthorized access to patient records	Possible	Possible	High
Data breach through cybersecurity	Possible	Possible	High

Step 6: Measures to reduce risk

Risk	Options to reduce or eliminate risk	Effect on risk (Eliminated, reduced, accepted)	Residual risk (Low, medium, high)	Measure approved (Yes/no)
Limited improvement in health outcomes	Monitor patient outcomes	Reduced	Low	Yes
High implementation and training costs	Provide staff training	Reduced	Low	Yes
Internet dependency and reduced interaction	Maintain reliable internet	Reduced	Low	Yes
Downtime increases prescribing errors	Use backup procedures	Reduced	Low	Yes
Inaccurate stock without monitoring	Conduct regular stock checks	Reduced	Low	Yes

Non-compliance reduces system effectiveness	Monitor staff compliance	Reduced	Low	Yes
Unauthorized access to patient records	Use role-based access	Reduced	Low	Yes
Data breach through cybersecurity	Use encryption and firewalls	Reduced	Low	Yes

Step 7: Sign off and record outcomes

Item	Name/Date	Notes
Measures Approved By	Alicia Thomas 14 August, 2026	Security controls approved before implementation.
Project Plan Integration	Marian Miro 14 August, 2026	Security actions integrated into development schedule.
Residual Risks Approved By	Matt Zavín 14 August, 2026	Remaining risks accepted after mitigation.

DPO Advice Summary:
Approved by Alicia Thomas.

DPO advice accepted or overruled by:	Approved By Legacy Rules, 14 August, 2026	If overruled, you must explain your reasons.
--------------------------------------	---	--

Comments: All responses were reviewed and considered before approval.

Consultation responses reviewed by:	Hugo Williams 14 August, 2026	If your decision departs from individuals' views, you must explain your reasons
-------------------------------------	----------------------------------	---

Comments: All responses were reviewed and considered before approval.

This DPIA will keep under review by:	Kunjan Tamang 14 August, 2026	The DPO should also review ongoing compliance with DPIA
--------------------------------------	----------------------------------	---

References

Zax, D. (2026), *'What is a DPIA (Data Protection Impact Assessment)?'*. Available at:

<https://edwebcontent.ed.ac.uk/sites/default/files/atoms/files/researchdpiaguidancev5.pdf>

<https://www.ibm.com/think/topics/data-protection-impact-assessment>

Parliament of Victoria (2026), Health Records Act 2001 (Vic), p. 115.

Available at:

<https://content.legislation.vic.gov.au/sites/default/files/2026-04/01-2aa050-authorised.pdf> pp.115

*Data Protection Commission (2026) 'Data Protection Impact Assessments'. Available at:
<https://www.dataprotection.ie/en/organisations/know-your-obligations/data-protection-impact-assessments>*

*GDPR.eu (2019) Sample DPIA template. Available at:
<https://gdpr.eu/wp-content/uploads/2019/03/dpia-template-v1.pdf>*